

OT/ICS Cybersecurity Cheat Sheet

CISO-style quick reference for Operational Technology, Industrial Control Systems, and safety-focused cybersecurity.

One sentence to remember

IT cybersecurity mainly protects information systems and data. OT/ICS cybersecurity protects physical processes such as water, power, manufacturing, transport, and building systems. In OT, a cyber event can become a safety, production, or public-service incident.

1. Core Mental Model

The simplest OT/ICS loop is:

Sensor Measures real world	PLC Input Receives value	PLC Logic Applies rules	PLC Output Sends command	Actuator Moves equipment	Physical Process Changes in real world
Water level = 65%	Level signal enters controller	If level > 95%, stop pump	Stop-pump command	Pump stops / valve opens	Tank level changes

2. Key OT/ICS Terms

Term	Simple meaning	CISO/security importance
OT	Operational Technology: systems that monitor or control physical processes.	Compromise can affect safety, production, or public services.
ICS	Industrial Control Systems: OT used for industrial control.	Includes PLCs, SCADA, DCS, HMIs, RTUs, and engineering stations.
PLC	Programmable Logic Controller: industrial controller that reads inputs and sends outputs.	Unauthorized logic changes can directly change physical behavior.
HMI	Human Machine Interface: dashboard used by operators to monitor and control processes.	Protect access; one wrong or malicious command may affect operations.
SCADA	Supervisory Control and Data Acquisition for large or distributed environments.	Used in utilities, pipelines, transport, and energy networks.
DCS	Distributed Control System used in plants with many controllers.	Common in chemical, refinery, power, and process industries.
RTU	Remote Terminal Unit used to collect/control data at remote sites.	Often found in geographically distributed infrastructure.
Historian	Database collecting process values and events over time.	Useful for monitoring, investigations, and operational analytics.
Engineering workstation	System used to configure PLCs and industrial devices.	Highly sensitive; compromise may allow logic or configuration changes.

3. IT vs OT Priorities

Dimension	Traditional IT	OT/ICS
Primary concern	Confidentiality, integrity, availability of data and services.	Safety, reliability, availability, process integrity, and controlled recovery.
Impact of incident	Data leak, service outage, fraud, regulatory exposure.	Physical disruption, equipment damage, production stop, environmental/safety consequences.
Change rhythm	Frequent patching, upgrades, reboots are normal.	Changes require testing, maintenance windows, vendor input, safety validation.
System lifetime	Often 3-7 years.	Can be 10-30 years or more.
Security design	Modern OS, identity, logging, encryption more common.	Legacy protocols and devices may lack encryption, authentication, or logging.
Best mindset	Protect data and digital services.	Keep the physical process safe, predictable, and recoverable.

Memory rule

IT often starts with CIA: Confidentiality, Integrity, Availability. OT starts with Safety: never let cybersecurity actions create unsafe process behavior. Security must work with engineering, operations, safety, and vendors.

4. Purdue Model - Simple OT Network Map

Level	Zone	Examples	Security objective
5	Enterprise	Internet, email, ERP, corporate apps	Normal IT security controls; prevent phishing/malware reaching OT.
4	Business planning	Business systems, reporting, scheduling	Limit data flows toward OT; no direct control access.
3.5	Industrial DMZ	Jump servers, patch repos, historians, file transfer gateways	Controlled buffer between IT and OT.
3	Site operations	OT servers, historians, domain services, manufacturing systems	Central OT services; strict access and monitoring.
2	Supervisory control	HMI, SCADA servers, engineering workstations	Protect operator control and engineering functions.
1	Basic control	PLCs, RTUs, IEDs, controllers	Protect logic, commands, and controller communications.
0	Physical process	Sensors, pumps, valves, motors, breakers	Keep people, equipment, and process safe.

Segmentation principle

A compromised office laptop should not be able to reach an HMI, engineering workstation, or PLC. Use zones, conduits, industrial DMZs, jump servers, firewalls, allowlists, and monitored remote access.

5. Water Tank Story - From Lab to Real Risk

Training example: an HMI shows a tank level at 65%. When the pump starts, the level rises. An alert appears at 85%, and the pump shuts off at 95% to avoid danger. When the outtake valve opens, the water level lowers.

CISO lesson: in OT, a dashboard action is not just a click. It can start a motor, open a valve, shut down a process, or change a safety-critical state.

6. Main OT/ICS Cyber Risks

HMI compromise

Attacker or unauthorized user can view alarms, hide process reality, or issue harmful commands.

PLC logic tampering

Unauthorized change to controller logic can make a process behave incorrectly or unsafely.

Spoofed sensor values

Operator may see normal values while the real physical process is abnormal.

Ransomware cascade

IT ransomware can force OT shutdown if shared services, domain accounts, or visibility are affected.

Weak vendor access

Permanent VPNs, shared accounts, or no MFA can become an easy entry path.

Flat networks

Lack of segmentation allows lateral movement from IT to OT or across OT zones.

Poor asset inventory

Unknown PLCs, HMIs, versions, and remote paths cannot be properly protected.

Unsafe security testing

Aggressive scanning or untested controls may disrupt fragile industrial devices.

7. CISO Control Checklist

Control area	What good looks like	Why it matters
Asset inventory	Know PLCs, HMIs, servers, engineering stations, network devices, firmware, owners, criticality.	No inventory = no prioritization, no response, no risk view.
Segmentation	Separate IT/OT; use OT zones, industrial DMZ, firewalls, allowlists, no direct internet exposure.	Stops one compromise from becoming a plant-wide incident.
Remote access	MFA, jump server, approval workflow, time-limited access, session recording, vendor governance.	Vendor paths are high-risk and must be controlled.
Identity and privilege	Named accounts, least privilege, PAM for privileged access, no shared admin accounts where avoidable.	Improves accountability and reduces misuse.
Change management	Approve, test, document, and back out PLC/HMI/SCADA changes.	Prevents accidental or malicious process changes.
Backups	Offline/immutable backups of PLC logic, HMI configs, SCADA servers, historians, engineering workstations.	Recovery requires more than normal file backups.
Monitoring	Passive OT-aware monitoring, logs from jump servers, servers, firewalls, and critical applications.	Detect anomalies without disrupting fragile devices.
Vulnerability management	Prioritize by exploitability, exposure, safety impact, asset criticality, and maintenance windows.	OT patching is risk-managed, not blind patching.
Incident response	OT-specific playbooks with operations, engineering, safety, vendors, legal, comms, and executives.	Generic IT playbooks can be unsafe in OT.

8. OT Incident Response - CISO Decision Flow

Phase	CISO focus	Key questions
1. Detect	Confirm whether the event affects IT only, OT support systems, or control systems.	What changed? What alarms appeared? Are sensor values trustworthy?
2. Stabilize safety	Coordinate with plant operators before isolating or shutting down systems.	Could a cyber containment action create unsafe physical behavior?
3. Contain	Block attacker paths while preserving safe operations.	Can we isolate through firewall rules, jump access removal, account disablement, or vendor access pause?
4. Investigate	Collect evidence from servers, jump hosts, firewalls, historians, EDR where safe, and OT monitoring.	Was PLC logic changed? Were commands issued? Which accounts were used?
5. Recover	Restore trusted configurations, validate process state, recover servers, and test before returning to normal.	Do we have clean backups and engineering validation?
6. Learn	Update architecture, playbooks, monitoring, segmentation, access rules, and tabletop exercises.	Which control failed, and how do we reduce recurrence?

9. Do / Do Not

Do	Do not
Coordinate every major action with operations and engineering.	Do not disconnect industrial systems without understanding the physical process impact.
Use passive discovery and OT-aware monitoring where possible.	Do not run aggressive scans on fragile OT networks without approval and testing.
Prioritize safety, reliability, and controlled recovery.	Do not treat OT exactly like a normal office IT network.
Back up PLC logic, HMI configurations, and SCADA systems.	Do not assume normal server backups are enough for OT recovery.
Use MFA, jump servers, PAM, and session recording for remote/vendor access.	Do not allow permanent, unmonitored vendor VPN access.

10. Quick Exam / Interview Recall Cards

Question	Answer to remember
What does OT mean?	Operational Technology.
What does ICS mean?	Industrial Control Systems.
What is the most important OT security requirement?	Safety.
What does an HMI do?	It lets a human operator monitor and control a physical process.
What provides environmental/process data to a PLC?	Sensors.
What connection type does a PLC use to command real-world devices?	Output.
What is the PLC?	The industrial controller that reads inputs, runs logic, and sends outputs.
Why is OT patching difficult?	Downtime, safety validation, vendor dependencies, legacy systems, and maintenance windows.
Why is encryption sometimes missing?	Many legacy OT protocols were designed for isolated, reliable operations rather than modern security.
What is the big CISO concern?	A cyber incident can affect physical operations, safety, and business continuity.

Final memory sentence

OT/ICS security is not only about protecting computers. It is about protecting trust in physical operations: the operator must trust the HMI, the PLC must trust inputs, the actuator must receive the right command, and the business must trust that the process can recover safely.